HSLU Lucerne University of Applied Sciences and Arts

Product Security Lifecycle - Secure Development 3

SPREN
Alex Diekmann



Information Technology
March 10, 2026

FH Zentralschweiz

What you will learn

Part 1

- **Understand** the difference between **Product Cyber Security** and Information Security
- Know and **apply relevant** Laws, Regulations and **Standards** for specific target markets
- **Understand involved roles**

Part 2

- Understanding **Product Security Activities** and **Deliverables** within an SDLC

Part 3

- **Build and integrate an SDLC** for Product Security purpose based on relevant standards
- **Explain** to Management and Developers **why** Product Security is essential
- **Adapt to** organizational **changes**

Deep Dives

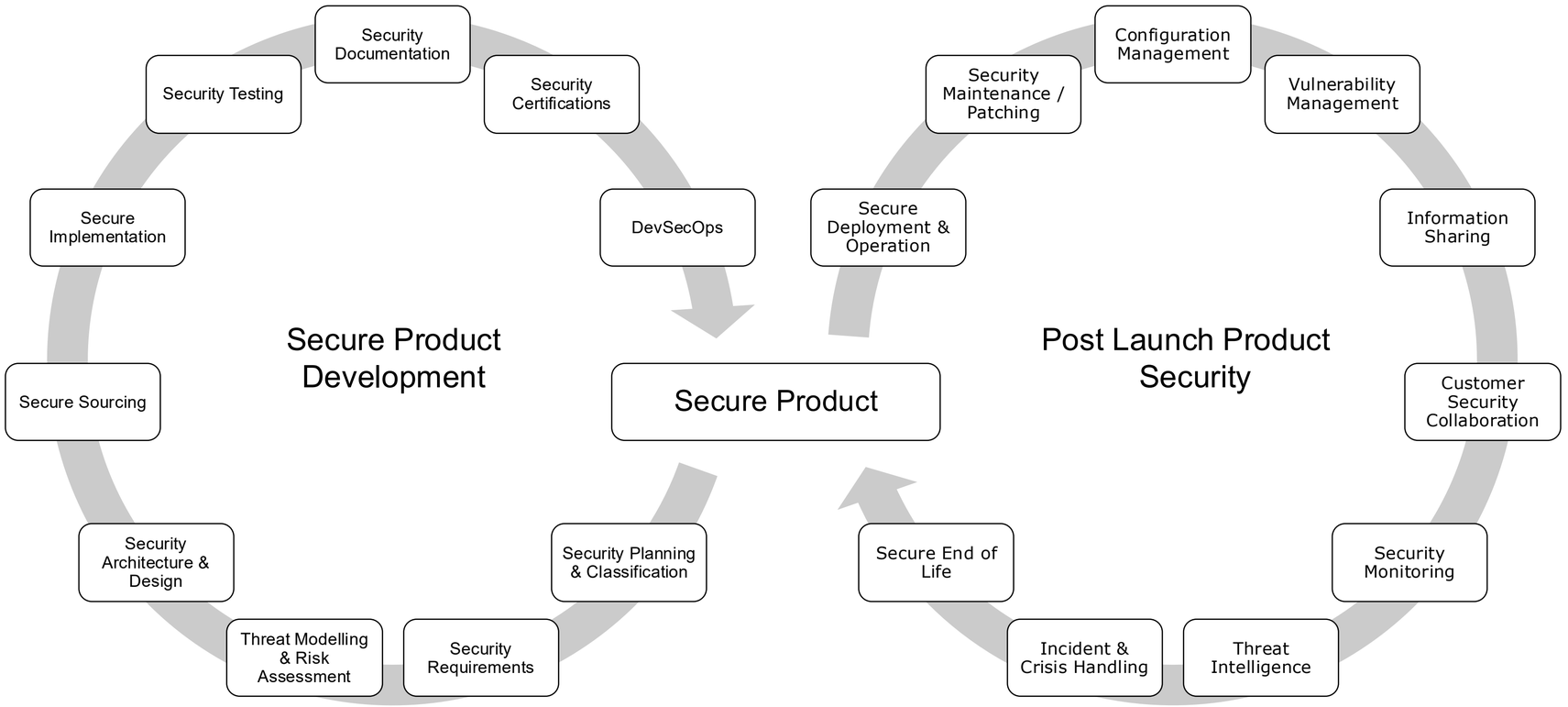
- **Security Architecture & Design** in context of IEC 62443
- How to do **Product Security Risk Management**
- How to ensure **Supply Chain Security**

Other lectures

- ➢ **SPRG**
- Microsoft SDL
- Threat Modeling with STRIDE / DREAD
- Requirements Management

- ➢ **IoT Security**
- ➢ **Cloud Security**
- ➢ **Information Security Fundamentals**

Product Cybersecurity Lifecycle



Cyber Security Management System(s)

Development & Production Security

Security Risk Management

Organization, Culture, Awareness & Training

Supply Chain Security

HSLU Lucerne University of Applied Sciences and Arts

How to establish Product Cybersecurity

Cybersecurity Management System

Information Technology
March 10, 2026

FH Zentralschweiz

Security Governance Summary

Goal

- Ensure Product Security is adequately addressed in the entire Product Lifecycle
- Keep Management up to date

Deliverables

- Communicated Security Policies & Processes
- Ensured Adherence to Policies & Processes
- Security Steering & Management Review
- Security Audits & Reviews
- KPIs

Prerequisites

- Security Experts
- Security Policies & Standards
- Mature development process
- Stakeholder sign-off on deliverables

Responsibilities

Responsible:	Security Management
Accountable:	Company Management
Supporting:	Senior Management
Consulted:	All Staff
Informed:	All Staff



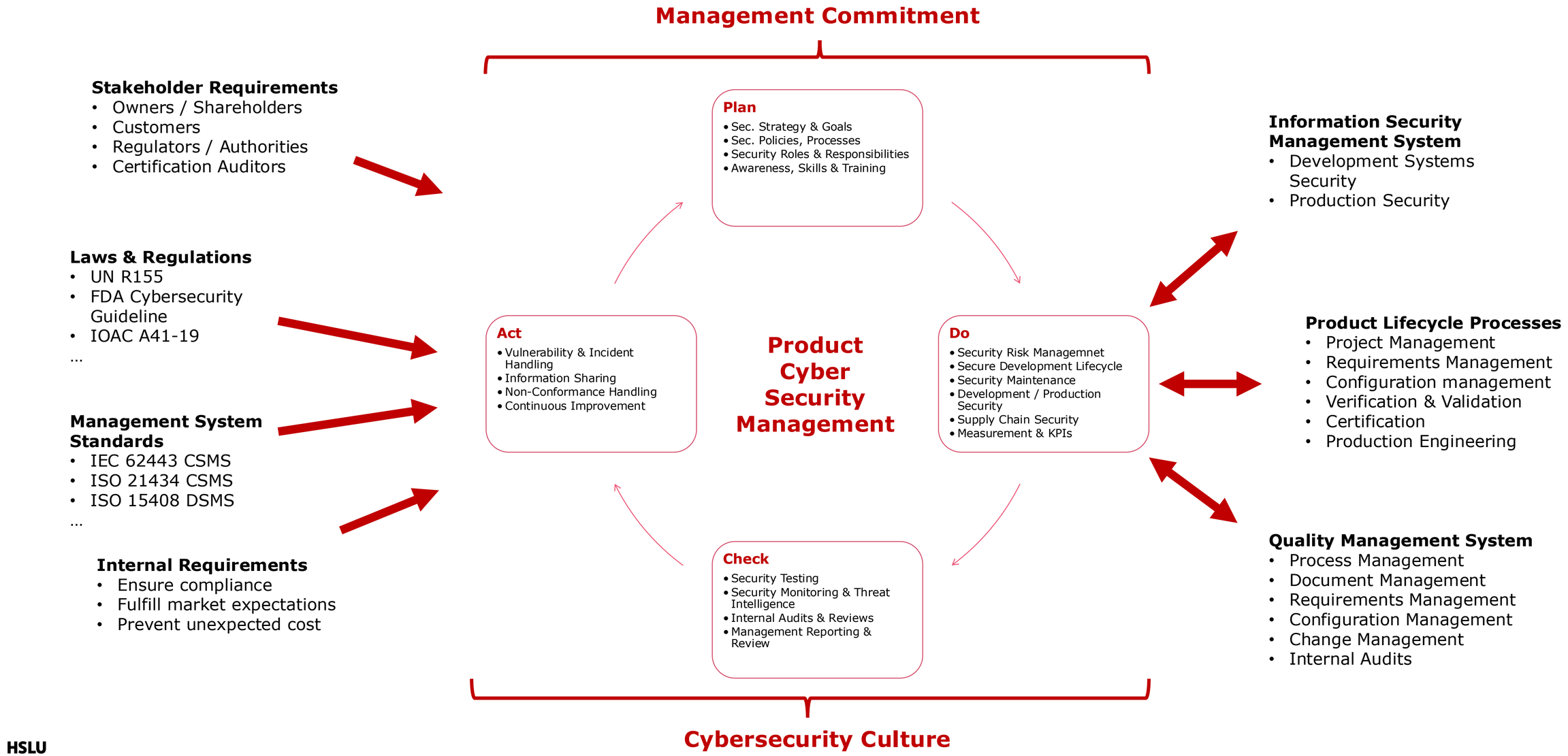
1. Plan → 2. Do → 3. Check → 4. Act

- Involve stakeholder for planning & checking
- Regular reviews & reporting
- Emphasize the why



- Violations without consequences
- Rules without rationale
- Uncontrolled exceptions

Cybersecurity Management System in a Nutshell



How to establish Product Security Management



How to develop a (Security) Policy

1. **Identify** the **owner** and **stakeholders**
2. **Collect Requirements** (Laws & Regulations, External & Internal Standards, Stakeholder Requirements)
3. **Draft** first version
4. **Find** and **fix gaps** to Requirements
5. **Review** with stakeholders
6. **Training Material**
7. **Sign off**, communicate & train
8. **Regular Review**

- Ensure proper document control
- Short & Concise main body
- Focus on what the people must remember
  (Highlight max. 5 responsibilities)
- **Don’t expect people to read!**
  Instead, provide
  - per-role Training,
  - Templates with descriptions
  - Detailed Process Documents & Guidlines

Example Policy Structure

0. Document Information
(e.g. ID, Owner & Approvers, Effective Date, Review Cycle, Version History)

1. **Introduction**
   1. Context
   2. Purpose
   3. Scope (in & out)
2. **Management Commitment**
   As leaders of this company, we recognize…
3. **General Policy & Principles**
   It is our policy to….
4. **Roles & Responsibilities**
   All employees shall ensure…
5. **Definitions, References**

A. Detailed Sub-chapter per Topic
1. Purpose & Goal(s)
2. Deliverables
3. Detailed Policies / Rules per Topic

How to develop a Process

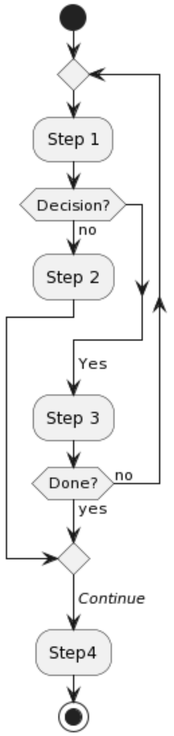
1. **Determine** Process **Owner** & Manager
2. **Define Purpose**, Goal and Scope
3. **Define Steps** & Decision Points
4. **Link** with **other Processes**
5. **Define Inputs**, **Outputs**, required tools & KPIs
   SIPOC
6. **Align** on **Responsibilities** RA(S)CI
7. **Document** the Process and create **Training Materials**
8. **Test** in a pilot scope & **Refine**
9. **Rollout** & Train broadly
10. **Monitor** & Continuously Improve

- Use Process Management **Tools** where available
- Use **RASCI** for Responsibilities per step
  - **R**esponsible – Executes the step
  - **A**ccountable – Ensures the process is lived
  - **S**upporting – Supports the Responsible
  - **C**onsulted – May be pulled in to help
  - **I**nformed – is informed when the step happens / is completed
- Define as **few steps** as possible
- Cover **details** in **templates** / **trainings** / **guidelines**

Example SOP Structure

0. Document Information
(e.g. ID, Owner & Approvers, Effective Date, Review Cycle, Version History)

1. **Introduction**
   - Context
   - Purpose
   - Scope
2. **Roles & Responsibilities**
3. **Process Overview**
   - Process triggers
   - Flowchart
   - Steps, each with
     - Description
     - Inputs & Outputs
     - RASCI
     - Interfaces
4. **Deliverables & Tools**



How to sell it

Facts

- Show the Current state
- Find and show applicable laws
- Explain consequences of breaches
- Connect threats to business impact

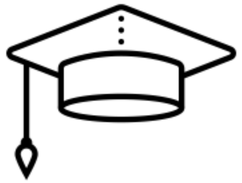
Figures

- Estimate Financial impact
- Show industry statistics
- Estimate buildup efforts & cost (Detailed breakdown!)

Feelings

- Ask for their perspective (active listening!)
- Acknowledge business priorities
- Acknowledge need to cost-save
- Acknowledge your estimates will be wrong

Quiz



1. What's a shared requirements of ISO21434 and ISO9001

a) Management Review

b) Internal Audit

c) Threat Analysis and Risk Assessment

d) Cybersecurity Culture

2. Which acronym describes a common approach to governance

a) SIPOC

b) PDCA

c) RASCI

d) STRIDE

3. Why is establishing a cybersecurity culture important?

a) People would otherwise blindly follow security policies without questioning them

b) This approach will eliminate all security vulnerabilities

c) The secure way should become the default choice while developing products

d) It won't work anyway

HSLU Lucerne University of Applied Sciences and Arts

How to establish Product Cybersecurity

Development & Production Security

Information Technology
March 10, 2026

FH Zentralschweiz

Development & Production Security Summary

Goal

- Protect development- and manufacturing related Data, Infrastructure, IT Systems, Processes and Environments from Security Threats

Deliverables

- Operations Policies & Training
- Physical Security Controls for facilities & server rooms
- IT Security controls for infrastructure (Development / Manufacturing)
- Security Monitoring

Prerequisites

- Security Policies & Standards
- Security covered in contracts (outsourced infrastructure)
- Security collaboration with stakeholders
- Asset Inventory

Responsibilities

Responsible:	Security Management
Accountable:	Senior Management
Supporting:	IT
	R&D,
	Site Management
	Production Management
Consulted:	Quality, Sourcing
Informed:	Dev. & Prod. Staff

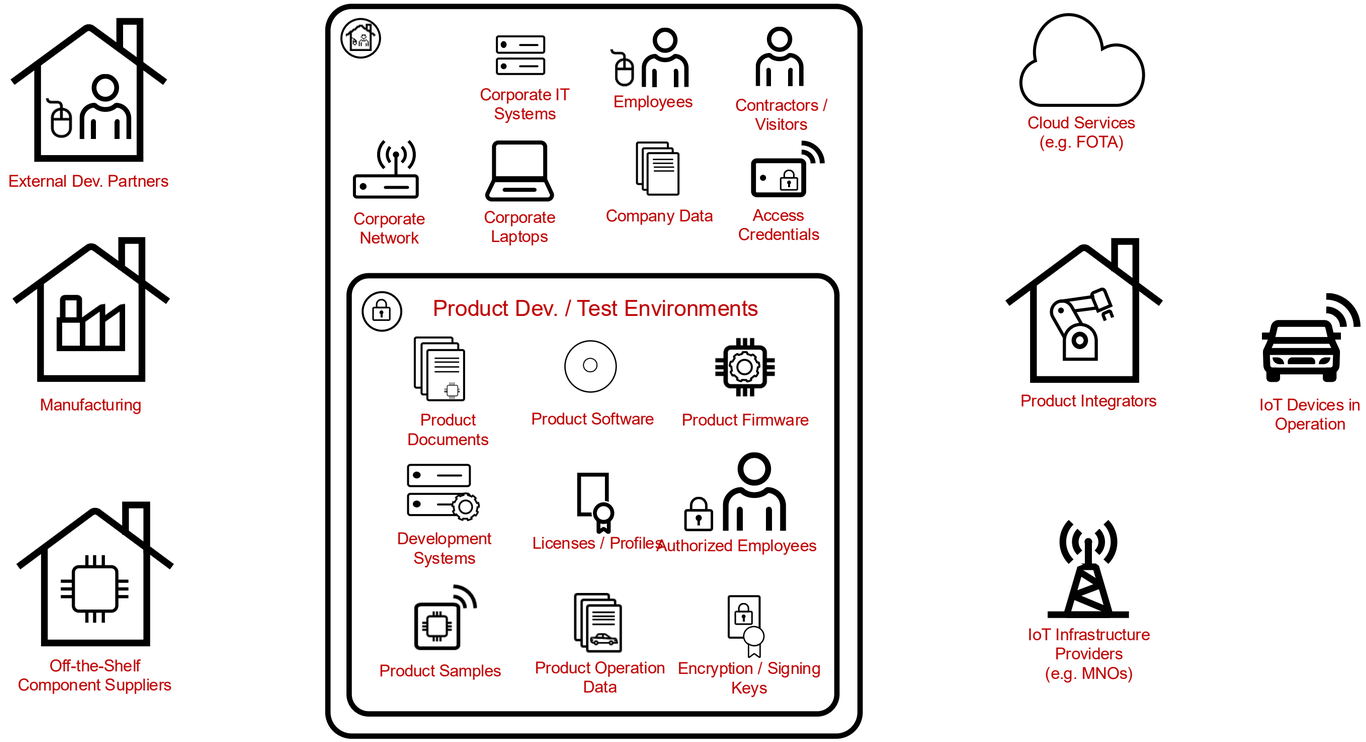
1. Threat Modelling on processes & assets → 2. Risk Assessment → 3. Implement Mitigations → 4. Monitor Operation

- Integrated Risk Analysis
- Interface with Information Security & Physical Security
- Involve stakeholders

- Too much detail
- Trusting plans & other paper
- Lack of Business Continuity Managemnet

Exercise: Development Security Threats

Identify Threats for a Development Organization

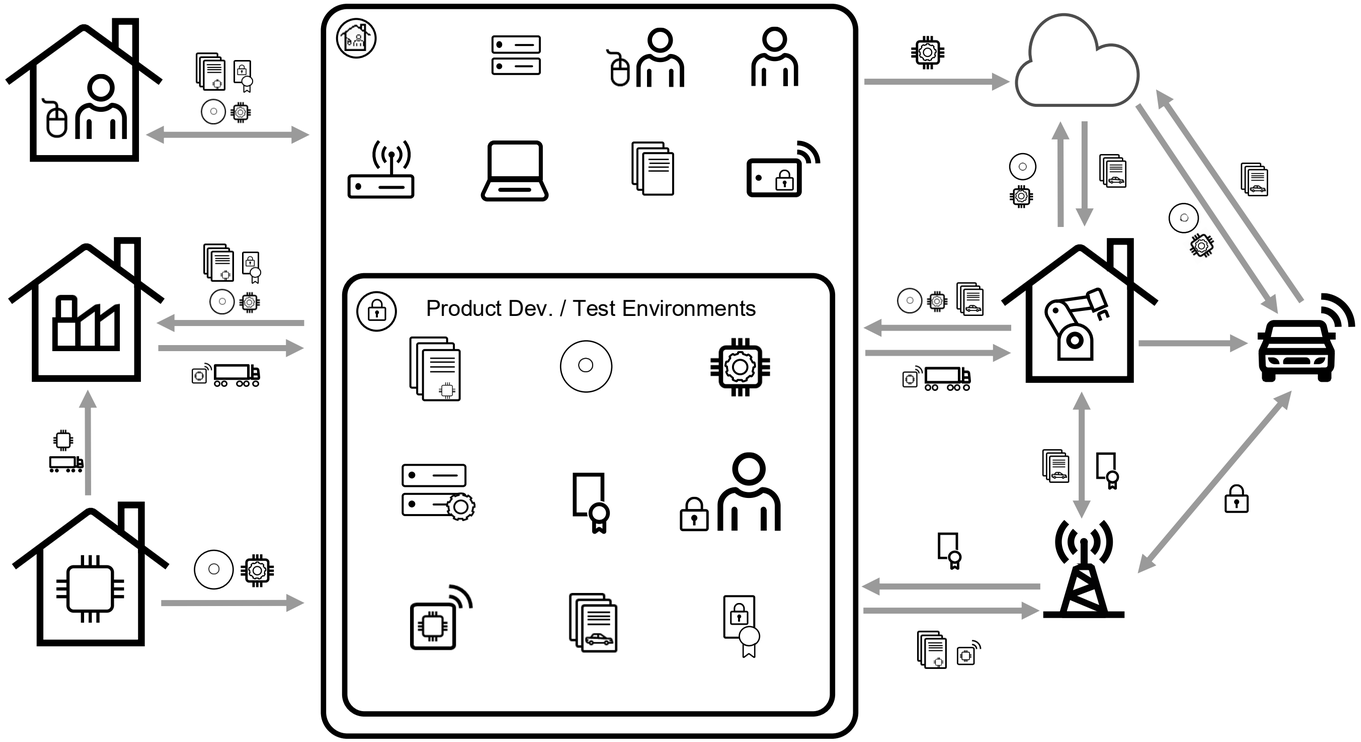


Which threats do you see related to people & assets?

Source: “IoT Security – the 3rd Line of Defense”, A. Diekmann - © u-blox AG 2019

Exercise: Development Security Threats

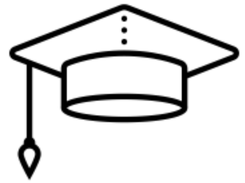
Identify Threats for a Development Organisation



What about data flows and interfaces?

Source: “IoT Security – the 3rd Line of Defense”, A. Diekmann - © u-blox AG 2019

Time to rest



10 Min Break

HSLU Lucerne University of Applied Sciences and Arts

How to establish Product Cybersecurity

Organization, Culture, Awareness & Training

Information Technology
March 10, 2026

FH Zentralschweiz

Security Culture, Awareness & Training Summary

Goal

- Get Buy In for security from the people
- Ensure that people know and adhere to policies and procedures
- Help people identify and react appropriately to security threats

Deliverables

- Security Awareness Trainings
- Security Policy & Process Trainings
- Technical Security Trainings
- Secure Coding Trainings
- Incident Response Exercises

Prerequisites

- Management Commitment
- Defined policies, processes and standards
- Guidelines / How Tos
- Training Material
- Learning tools

Responsibilities

Responsible:	Security Management
Accountable:	Company Management
Supporting:	Senior Management
Consulted:	All Staff
Informed:	All Staff

1. Identify Content & Audience
2. Define Method & Medium
3. Develop & Set up Training
4. Execute & Document
5. Evaluate & Improve

- Kippling Method (Cover Why, what, who, how, when, where)
- Regular Re-Training
- Target Audience



- Too much detail / too generic
- Too wordy
- Lack of exercises

Changing the culture – How to make it work

Facts



- Train the rules
- Explain the drivers
- Talk about past incidents
- Demonstrate the how
- Show issues and how to address them

Figures



- Track customer requests
- Calculate the business-case
- Involve dev. teams to define and track KPIs
- Track improvements

Feelings



- Management Commitment
- Involve the team in effort estimation
- Acknowledge the inconvenience of security
- No blame
- Celebrate successes
- Be there to help

HSLU Lucerne University of Applied Sciences and Arts

Product Cybersecurity & Organizational Changes

Mergers / Acquisitions / Divest

Information Technology
March 10, 2026

FH Zentralschweiz

Acquisitions gone wrong

Facebook Walks Away From Tiktok's Forebear

Fortune reports that in 2016, Facebook spent months considering a possible acquisition of Musical.ly, which later became TikTok, the massively popular video app. Facebook passed on the deal because of two concerns: the app was based in China, and its predominately underage user base would likely run afoul of American laws governing child internet privacy.

Source: auth0.com

Marriott Acquires Starwood... and a Major It Headache

Then, in 2018, Marriott revealed that Starwood had suffered a massive data breach, in which nearly 400 million guest records were exposed through a security flaw in Starwood's reservation system. The flaw in Starwood's system had existed since 2014, long predating Marriott's acquisition. But when the breach was discovered in 2018, two years after the deal, Starwood's reservation system still hadn't been migrated to Marriott's.

Source: auth0.com

KEY FINDINGS

- **Cybersecurity issues are prevalent and can put a deal into jeopardy:** Over half of respondents (53%) report their organization has encountered a critical cybersecurity issue or incident during an M&A deal that put the deal into jeopardy.
- **Organizations are placing more focus on a target's cybersecurity posture than they did previously:** Eighty-one percent of ITDMs and BDMs agree that they are putting more of a focus on a target's cybersecurity posture than in the past, highlighting that cyber is a top priority for both IT and business decision makers.
- **An undisclosed data breach is a deal breaker for most companies:** Seventy-three percent of respondents agreed that a company with an undisclosed data breach is an immediate deal breaker in their company's M&A strategy.
- **Decision makers sometimes feel they don't get enough time to perform a cyber evaluation:** Only 36% of respondents strongly agree that their IT team is given time to review the company's cybersecurity standards, processes and protocols before their company acquires another company.
- **Internal IT teams may lack the skills to conduct cybersecurity assessments:** Among ITDMs, only 37% strongly agree that their IT team has the skills necessary to conduct a cybersecurity assessment for an acquisition.
- **Organizations allocate third party resources to their cybersecurity assessments:** Nearly all respondents (97%) reported that their organizations spend money on outside contractors for IT audits or cybersecurity risk assessments.
- **Connected devices and human error put organizations at risk:** When asked what makes organizations most at risk during the information and technology process, two answers stood out: human error and configuration weakness (51%) and connected devices (50%).
- **Devices often get overlooked and missed during integration:** Over half (53%) of ITDMs say they find unaccounted for devices after completing the integration of a new acquisition.
- **Failure to address cyber risk can lead to major acquisition regrets:** Nearly two-thirds of respondents (65%) said their companies experienced regrets in making an M&A deal due to cybersecurity concerns.

Source: 2019 Study "The Role of Cyberasecurity in M&A Diligence" forescout.com

Organizational Change Types

	Merger	Acquisition	Divest
			
What happens	Fusion of two organizations	(Usually larger) company buys other company	Company sells of a part of their business
Types			
Business Drivers	• Survival • Market Share • Added Value • Diversification	• Buy IP • Extend Capabilities • Extend Revenue • Future Growth • Customer Base • Eliminate Competitor	• Financial Survival • Increase Profitability • Strategic Focus • Owner motivation
Targets / Partners	• Equal-sized competitors • Companies in new markets • Suppliers	• Smaller competitors • Start-ups • Suppliers	• Competitors • Investors • Private buyers
Who in Control	(Normally) both organizations	Buyer (& Owners of target)	Owners (Seller) / Buyer

Merger / Acquisition / Divest Phases*



Selection

- Selection Requirements
- Candidate Evaluation
- Candidate Selection



Due Diligence & Closing

- Information Gathering
- Data Analysis
- Risk Identification
- Negotiation
- **Closing**



Integration / Separation

- People
- Organization
- Product Portfolio
- Processes
- Infrastructure

* Product Security Perspective

Merger & Acquisition Product Security Goals

Selection Phase

- Cover Security Requirements
- Identify Suitable Candidates
- Security Criteria considered for selection



Due Diligence & Closing Phase

- Ensure Product Security Risks are tolerable
- Identify Product Security Opportunities
- Provide go / no-go decision input from a Product Security perspective
- Ensure Acceptable Contract Terms



Integration Phase

- Integrate the Security Organization
- Integrate the Processes & IT Systems
- Integrate the Products

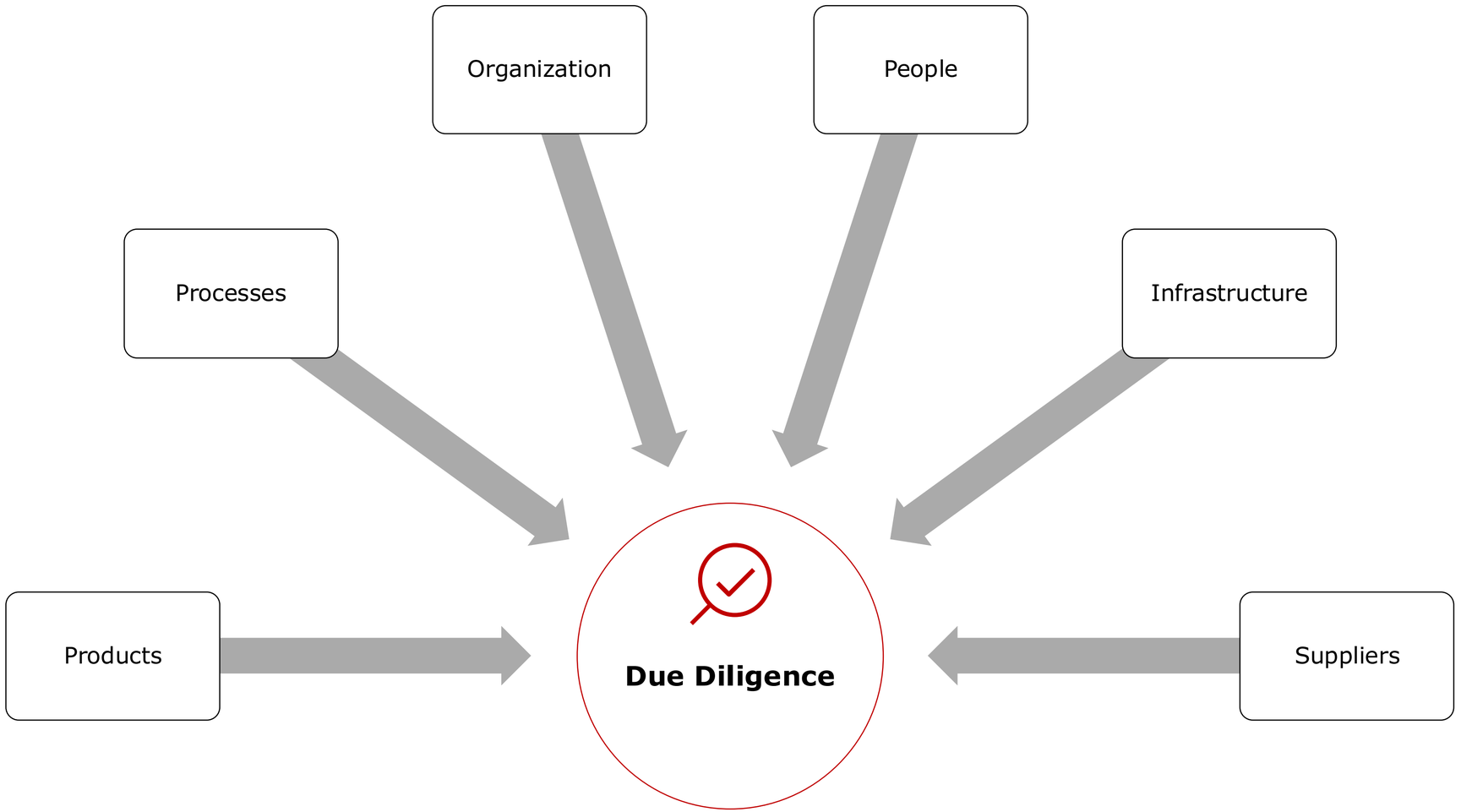


Separation Phase

- Ensure Business Continuity
- Separate Product Portfolios & Processes
- Separate Production & Backend IT Systems
- Secure Asset Handover
- Separate Organization



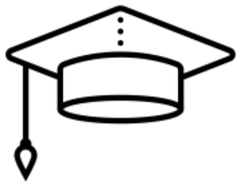
Due Diligence – Topics to cover



Challenges

	Selection	Due Dilligence & Closing	Integration	Separation
Challenges	• Lack of involvement • (Due) Confidentiality • Security not primary Concern	• Lack of Data & Access • Time & Resources • Collaboration • Conflicting Priorities • Diverging Motivation • (Due) Confidentiality	• Cultural Differences • Integrating Products & Infrastructure • Change resistance • Power Play & Politics • Hidden Issues	• Imprecise Cuts • Leavers • Time & Resources • Hidden Issues • Interconnectedness • Contractual constraints
Do's	✓ Treat as secret ✓ Focus on key risks ✓ Simple selection criteria	✓ Treat as secret ✓ Cover technical and process aspects ✓ Interview various roles ✓ Involve experts for product review	✓ Clear accountability & timelines ✓ Address the Organization first ✓ Leverage bought-in know-how	✓ Focus on business continuity ✓ Well-maintained process descriptions & asset inventory ✓ Transition Agreements with enough time
Don'ts	➢ Don't talk about the project ➢ Don't expect highest priority for security	➢ Don't talk about the project ➢ Don't expect transparency from the candidate ➢ Don't believe documents	➢ Don't break & rebuild > iterative integration ➢ Don't expect people to stay ➢ Don't accept non-integration	➢ Looking into segregation efforts after closing ➢ Forced friends forever ➢ Don't expect people to stay

Organizational Change – Exercise

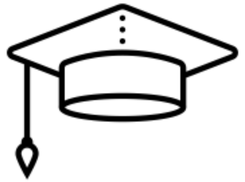


Your company plans to acquire a small 20 person start up that offers a big data cloud service to mass-process anonymous location data and movement profiles.

You become involved close to the end of the due diligence phase to make a judgement on Product Security and associated risks

- To get a first impression, you get to interview the CEO for 60 minutes. Which questions would you ask about the company to gain an initial impression?
- You get two days to review the cloud product, with full access to the available documentation, people, source code and a test system. Which areas would you look at?
- You’re asked by the acquisition committee to give input for a buy / no-buy recommendation from the Product Security perspective. You’ve identified three major gaps during their review. How would you structure your presentation?

Time for questions





Contact Details



Alex Diekmann

e-Mail: alexander.diekmann@hslu.ch

Threema: 7SBWM9V7

LinkedIn: https://www.linkedin.com/in/alexdiekmann/

Contents of these slides may not be modified or re-used without prior approval of the author.

This presentation includes icons from the feather framework, which is published under the MIT license, and (where other sources are not specified) uses images from Wikimedia, released under Creative Commons 2.0 License or as Public Domain